

Mycroft.ai — Business Proposal

Team Mycroft.ai · IIT Bombay · Accenture Innovation Challenge 2026, Round 2

Submitted against Track 1: ControlPlane.ai

1. Executive summary

Enterprises are not deploying one AI system. They are deploying a portfolio of them — a customer-facing support assistant, an internal copilot, a decision-support tool inside a regulated workflow — and each carries a different risk signature, a different latency budget and a different regulatory obligation. A single Responsible AI checker applied uniformly across that portfolio will be too slow for the first, too noisy for the second, and too shallow for the third.

Mycroft.ai is a configurable Responsible AI control plane. It checks every AI interaction in real time, routes deeper evaluation where the risk justifies the cost, and — the part nobody else does — turns what it finds into a closable defect with a priced impact, a human-approved contract change, and a regression test that proves the fix held.

Three design commitments run through it:

1. **Governance is configuration, not code.** An Evaluation Contract, merged with a jurisdiction's policy pack, decides which checks run, how sensitive they are, and what happens when they fire. Changing the rules for the EU is a versioned config change, not a release.
2. **We never silently rewrite model output.** We detect, explain with pinned evidence, and then allow, log, route to a human, or block.
3. **Every number we report is measured or labelled.** The prototype produces its own precision, recall, false-positive and false-negative rates, its own latency distribution, and its own before/after regression result. Where a figure is an assumption, its formula and inputs are printed next to it.

The working prototype in this repository runs the whole loop on 294 simulated traces across all three use cases, with no API key and no network.

2. The problem, and why current approaches fall short

The risk families overlap. A fabricated detail about a named person is a hallucination and a privacy exposure at once. Systems that force a single category either lose the second risk or double-count the incident.

There is no real-time ground truth. The same knowledge gaps that cause a hallucination make automated verification of it hard. Checkers that promise to tell you whether a claim is *true* are promising something they cannot deliver.

One threshold cannot serve one company. Over-flagging causes alert fatigue and teaches users to click through warnings; under-flagging creates liability. Real systems must deliberately tune this trade-off per use case, and most tooling makes the trade-off invisible.

Regulation is a moving target with geographic variance. The DPDP Rules, the EU AI Act and US sectoral rules impose different obligations on the same model. Hard-coded rules age in months.

Enterprises cannot see inside the model. A foundation model consumed over an API offers logits at best; a checker must work at the input/output layer.

What exists today, and the gap

LAYER	WHO IS THERE	STATUS
Tracing and storage	Langfuse, LangSmith, Phoenix, Datadog	Commoditised. We read from it.
Guardrails and detection	Bedrock Guardrails, Azure Content Safety, Lakera, NeMo Guardrails	Crowded and increasingly free. Detection is not our moat, and we do not claim it is.
Evaluation and scoring	Braintrust, DeepEval, RAGAS, Galileo, Patronus, Arize	Crowded. Produces a score, not a diagnosis.
Configurable governance across a portfolio	thin	Policy is usually per-application, not a versioned artifact spanning use cases and jurisdictions.
Defect lifecycle: priced, owned, closed, regression-tested	empty	This is where we build.

The honest statement of our wedge: anyone can detect a PII leak. Almost nobody turns forty leaks into one owned defect, prices it under stated assumptions, carries the human's decision into a versioned contract, and then proves with a regression run that the change worked — and says what it cost.

3. Solution and architecture

Jurisdiction → Policy Pack → Evaluation Contract → Detector configuration

interaction → FAST LANE (inline, deterministic, 100% of traffic)

PII with checksum validation · deny lists · loop and budget breakers · revealed user signals

→ SLOW LANE (asynchronous, semantic, never blocks the user)

grounding against governed documents · counterfactual bias screen · explanation-policy checks

→ FUSION multi-label recorded, single strictest action taken

→ DEFECT clustered by failure signature, priced, evidence-pinned

→ HUMAN a reviewer confirms or rejects; nothing moves without this

→ CONTRACT versioned, git-diffable configuration change

→ REGRESSION re-run the defect's own traces; report benefit AND cost

→ AUDIT hash-chained record of every step

Why two lanes. Blocking a customer-facing response must be cheap, deterministic and defensible. Judging groundedness is none of those. Measured Fast Lane compute is p95 **under 0.05 ms** against a 100 ms contract budget; the Slow Lane runs asynchronously and never sits between the user and a response.

Why the contract is the centre. It is the only artifact a compliance officer, an engineer and an auditor can all read. It is human-approved, content-hashed, and diffable in git. The policy-pack merge is a ratchet: a jurisdiction

can raise strictness, never lower it.

Why the defect lifecycle. A dashboard of findings grows forever. A defect can be closed.

4. Target users

BUYER	THEIR PROBLEM	WHAT THEY GET
Head of AI / platform engineering (economic buyer)	Several AI systems in production, no consistent way to govern them	One control plane across the portfolio; per-use-case configuration without per-use-case code
Risk, compliance and DPO (approver)	Must attest to controls they cannot inspect	Versioned contracts citing the specific regulation, a hash-chained audit trail, and human approval built into the loop
Application engineer (daily user)	Told "the assistant is wrong sometimes" with no reproduction	A defect with a root cause, three example traces, evidence spans, and a regression set
Internal audit / external auditor (verifier)	Screenshots and a policy document	A chain that cannot be edited after the fact

Initial focus: Indian financial services and regulated SaaS — enterprises with DPDP obligations today, EU AI Act exposure by August 2026, and multiple AI use cases already live.

5. Three enterprise use cases

	CUSTOMER SUPPORT ASSISTANT	INTERNAL KNOWLEDGE ASSISTANT	DECISION-SUPPORT TOOL
Exposure	External, synchronous	Internal, synchronous	Regulated workflow
Risk posture	High	Medium	Very high
Latency budget	100 ms	250 ms	400 ms
PII	standard (strict in EU)	standard (strict in EU)	strict
Hallucination	standard	permissive — deliberately	standard (strict in EU)
Bias	off — no decisions about people	off	standard (strict in EU)
Policy	standard	standard	standard (strict in US)
High severity →	block	human review	block

The permissive hallucination setting on the internal assistant is a **deliberate governance choice**, not an oversight: the blast radius is an employee who can sanity-check the answer, and alert fatigue is the larger risk. The prototype measures exactly what that choice costs.

Under the EU policy pack the same 264 traces produce **112 blocks instead of 89**, with no code change.

6. Business case, with transparent assumptions

Every rupee figure below is produced by the prototype from stated inputs. The full register is `docs/ASSUMPTIONS.md` ; the formula is printed beside every figure in the app.

```
occurrence_rate      = occurrences in corpus / corpus size
monthly_occurrences = occurrence_rate x interactions_per_week x 4.33
cost_per_occurrence  = rework + (handoff_rate x handoff_cost) + churn_exposure
```

Worked example, measured on the corpus and priced with the customer support contract's assumptions (12,000 interactions/week; Rs 14 rework; 7% handoff at Rs 95; Rs 28 churn exposure):

DEF-EA14BE — "Response restates a governed figure incorrectly." 16 occurrences in 114 customer-support traces = a 14.0% rate → ~7,293 occurrences/month → **≈ Rs 3.55 lakh/month** for this one defect.

What this figure is and is not. It is an order-of-magnitude sizing of one failure mode under assumptions we chose and published. It is not a measured loss. A buyer who disagrees with the Rs 95 handoff cost changes one line in the contract and the number changes with it.

Pricing model. Platform subscription by governed interaction volume, with a floor: \$30k–150k ACV for an enterprise running 3–8 AI use cases. The buyer's comparison is not to a cheaper tool; it is to the cost of the compliance headcount currently reading traces by hand, plus the exposure of the failures nobody is reading.

Market. LLM observability tooling is a ~\$2.7B market in 2026 growing toward ~\$9.3B by 2030 (The Business Research Company). We do not compete for the tracing layer, which is commoditising. We sit above it.

7. Working prototype and methodology

`bash run.sh` — generates the corpus, produces the evidence pack, closes one defect loop end to end, and opens the prototype. No API key, no network.

Measured on 264 generated traces (jurisdiction IN):

RISK FAMILY	PRECISION	RECALL	FP RATE	FN RATE
Privacy	0.957	1.000	0.9%	0.0%
Hallucination	0.965	0.887	1.0%	11.3%
Bias	1.000	1.000	0.0%	0.0%
Policy	0.800	1.000	2.5%	0.0%
Behaviour	1.000	1.000	0.0%	0.0%

On 30 hand-written adversarial traces, written after the detectors were built: privacy 1.00/1.00, policy 1.00/1.00, bias 1.00/1.00, and **hallucination 0.857 precision at 0.750 recall**. That gap is real and we report it: the offline judge is built around figures, and open-ended fabrication with nothing numeric to contradict is its weakest case. It is also precisely why the LLM judge adapter exists.

The demo loop, measured: the defect above is confirmed by a reviewer, which adds `grounding_required: true` to the contract (revision 1 → 2, new content hash). Re-running the regression set of 30 traces: failures reaching the user fall from **6 to 3 (−50%)**, at a cost of **+11 hallucination false positives** and **+4 additional human reviews across 114 interactions**. Both directions are reported, every time.

Corpus construction, detector internals and every known failure mode: `docs/METHODOLOGY.md`.

8. Phased roadmap

Phase 1 — Read-only, 0–3 months. Ingest traces from the tracing layer the customer already runs. Slow Lane only, nothing inline, nothing blocked. Produce the first defect register and its pricing. The goal is a single meeting where a compliance officer sees a priced defect they did not know existed.

Phase 2 — Contracts and inline Fast Lane, 3–6 months. Author Evaluation Contracts with the customer's risk team. Deploy the deterministic Fast Lane inline behind a kill switch. Ship the first two policy packs (IN, EU).

Phase 3 — Close the loop, 6–12 months. Human resolution queue, contract versioning in the customer's own git, automatic regression sets, CI gate on their deploy pipeline.

Phase 4 — Portfolio, 12–24 months. Multi-use-case rollout, jurisdiction packs as a maintained subscription, shadow-call counterfactual bias screening against the live model, and a managed LLM-judge tier for the fabrication class the offline judge cannot reach.

9. Risks and mitigations

RISK	WHY IT IS REAL	MITIGATION
Detection commoditises	Model providers ship guardrails free	We do not sell detection. Detectors are pluggable; the contract, the lifecycle and the audit chain are the product.
Alert fatigue	Over-flagging is how these tools die	The trade-off is measured per threshold before a contract is signed, and review load is reported with every change.
The bias screen is over-read	"The tool said it's biased" is a headline risk for the customer and for us	Framed as a screening signal for human review everywhere it appears, in code, in the UI and in the report. Never as a finding of discrimination.
The offline judge misses open-ended fabrication	Measured: 0.75 recall on the holdout	Reported, not hidden. The LLM-judge adapter is built and this class is what it is for.
Cost figures are challenged	They are assumptions	Every input is in one file, printed beside every figure, and changeable by the buyer.
Regulation changes	It will	Rules live in versioned policy packs, not application logic. Adding a jurisdiction is a YAML file.
Latency	Inline checks on a customer-facing path	Fast Lane is deterministic and measured; anything semantic is asynchronous by construction.
We become the single point of failure	A control plane that fails closed takes production down	Fast Lane fails open with an audit record; the judge falls back to the offline path rather than erroring.